

Mapeo de Actores, Datos y Riesgos CIA

Nombre: MTG Companion

Integrantes: Vicente Fuentes, Tomás Rodríguez, Tomás Solano

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
Cliente	Foto del producto capturada por la cámara	Confidencialidad	El frontend procesa la imagen en el dispositivo, pero puede quedar en caché local, exponiendo el entorno del cliente sin cifrado adicional.
Cliente	Credenciales de acceso, correo y contraseña	Confidencialidad	El frontend envía las credenciales al backend por la red; sin HTTPS forzado en producción, quedan expuestas a interceptación.
Cliente	Token de sesión activa	Confidencialidad	El frontend guarda el token localmente, si un atacante inyecta código malicioso puede robarlo y suplantar al cliente ante el backend.
Cliente	Token de renovación de sesión	Integridad	El backend lo valida y rota en cada uso, pero si el frontend no lo consume bien, un token filtrado sigue vigente por semanas.
Cliente	Segundo factor de autenticación	Confidencialidad	Viaja entre frontend y backend al activarlo, interceptarlo en tránsito compromete la doble verificación de la cuenta en producción.
Administrador del sistema	Credenciales de la infraestructura en la nube	Confidencialidad	En producción dan acceso a servidores, base de datos y almacenamiento reales; una filtración compromete todo el servicio activo.
Backend	Secretos de configuración de pagos y sesión	Confidencialidad	Si se filtran en producción, comprometen pagos reales de clientes y la validez de todas las sesiones activas del sistema.
Backend, base de datos	Contraseña de usuario	Confidencialidad	Se guarda hasheada, pero una filtración masiva de la base en producción permite fuerza bruta offline sobre miles de clientes.
Backend, base de datos	Precio estimado del producto	Integridad	Lo calcula el frontend con IA embebida y lo envía tal cual; en producción un cliente podría alterar el valor antes de publicarlo.

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
Backend, API externa de pagos	Notificación de pago confirmado	Integridad	El backend valida la firma del proveedor externo, pero un secreto filtrado permitiría falsificar pagos entre clientes reales.
Servicio de almacenamiento de archivos	Fotos subidas por los clientes	Confidencialidad	Si el almacenamiento en producción queda mal configurado como público, expone fotos de miles de clientes reales.
Servicio de almacenamiento de archivos	Fotos subidas por los clientes	Disponibilidad	Una sola instancia sin redundancia deja sin servicio de fotos a todos los clientes durante una caída en producción.
Base de datos	Cuentas, productos y transacciones de todos los clientes	Disponibilidad	Sin redundancia ni respaldo automático, una caída en producción interrumpe el servicio completo para todos los clientes.
Proveedor de correo transaccional	Correos de bienvenida y comprobantes de pago	Confidencialidad	En producción debe ser un proveedor real y autenticado; uno mal configurado permitiría leer correos de cualquier cliente.
API externa de catálogo	Información y precio de referencia del producto	Disponibilidad	El frontend depende de ella en tiempo real para identificar productos; si cae en producción, el cliente no puede escanear nada.
API externa de catálogo	Resultados devueltos al buscar un producto	Integridad	Un cambio no controlado del proveedor externo puede alterar resultados de búsqueda sin que backend o frontend lo detecten.
Modelo de IA embebido en la app	Resultado de identificación, condición y precio	Integridad	Corre en el dispositivo del cliente sin firma ni verificación del backend; nada impide alterar el resultado antes de enviarlo.
Contraparte de una transacción	Código de verificación de la compraventa	Confidencialidad	Si el cliente lo comparte fuera de la app, en producción un tercero podría intentar interferir en una transacción real.
Backend	Probabilidad de premio en promociones internas	Integridad	Se valida y canjea en el backend, no en el frontend; evita que un cliente en producción se autoasigne un premio no autorizado.
Backend	Comunicación interna entre módulos de cuentas, pagos y catálogo	Integridad	Si un módulo interno no valida permisos antes de llamar a otro, un fallo puede exponer o alterar datos de otro cliente.

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
Cliente	Composición completa de su colección o inventario	Confidencialidad	En producción revela el valor total de los bienes de un cliente real, dato sensible ante robo de cuenta o ingeniería social.
Cliente	Acceso a la cámara del dispositivo	Disponibilidad	Si el cliente niega el permiso o el hardware falla, el flujo de escaneo y venta queda inutilizable sin alternativa manual.
Infraestructura en la nube	Estado y configuración de los servidores desplegados	Confidencialidad	Contiene metadata de todos los recursos productivos; expuesta, sería un mapa completo para atacar el servicio real.